ZAP Scanning Report

Target: https://monpasseport.ngser.com/

All scanned sites: http://monpasseport.ngser.com https://monpasseport.ngser.com

Javascript included from: http://monpasseport.ngser.com https://code.jquery.com https://monpasseport.ngser.com

Generated on Tue, 7 Feb 2023 17:04:48

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	5
Informational	2
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
CSP: Wildcard Directive	Medium	1
CSP: script-src unsafe-inline	Medium	1
CSP: style-src unsafe-inline	Medium	1
CSP: Notices	Low	1
Cookie No HttpOnly Flag	Low	20
Cookie Without Secure Flag	Low	40
Cross-Domain JavaScript Source File Inclusion	Low	1
X-Content-Type-Options Header Missing	Low	34
Information Disclosure - Sensitive Information in URL	Informational	3
Re-examine Cache-control Directives	Informational	17

Alert Detail

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	
Attack	

Evidence	frame-ancestors 'https://www.youtube.com/'
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	http://www.w3.org/TR/CSP2/ http://www.w3.org/TR/CSP/ http://caniuse.com/#search=content+security+policy http://content-security-policy.com/ https://github.com/shapesecurity/salvation https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	**CSP: script-src unsafe-inline**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	
Attack	
Evidence	frame-ancestors 'https://www.youtube.com/'
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	http://www.w3.org/TR/CSP2/ http://www.w3.org/TR/CSP/ http://caniuse.com/#search=content+security+policy http://content-security-policy.com/ https://github.com/shapesecurity/salvation https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	**CSP: style-src unsafe-inline**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	
Attack	
Evidence	frame-ancestors 'https://www.youtube.com/'
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	http://www.w3.org/TR/CSP2/ http://www.w3.org/TR/CSP/ http://caniuse.com/#search=content+security+policy http://content-security-policy.com/

	https://github.com/shapesecurity/salvation https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Low	**CSP: Notices**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	
Attack	
Evidence	frame-ancestors 'https://www.youtube.com/'
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	http://www.w3.org/TR/CSP2/ http://www.w3.org/TR/CSP/ http://caniuse.com/#search=content+security+policy http://content-security-policy.com/ https://github.com/shapesecurity/salvation https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Low	**Cookie No HttpOnly Flag**
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	https://monpasseport.ngser.com
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/accueil
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/connexion

Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/connexion?_token=ILhRotvhAAfloaBBijKO91agC0MY5S9W9zxVqEFq&connect_mode=email&email=foo-bar%40example.com&emailtel=ZAP&indicatif=ZAP&password=ZAP&tel=ZAP
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/demande_passeport
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/demande_passeport_diaspora
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/demande_passeport_resident
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/faq
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/inscription
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/modification_rdv
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/modifier_rdv
Method	GET
Parameter	XSRF-TOKEN

Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/modifier_rdv_diaspora
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/piece_a_fournir
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/piece_a_fournir_diaspora
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/reclamation
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/sampling
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/sitemap.xml
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/tuto_videos
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN

Instances	20
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	**Cookie Without Secure Flag**
Description	A cookie has been set without the secure flag, which means that the cookie can be accessed via unencrypted connections.
URL	https://monpasseport.ngser.com
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/accueil
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/accueil
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/connexion
Method	GET
Parameter	laravel_session
Attack	

Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/connexion
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/connexion?_token=ILhRotvhAAfloaBBijKO91agC0MY5S9W9zxVqEFq&connect_mode=email&email=foo-bar%40example.com&emailtel=ZAP&indicatif=ZAP&password=ZAP&tel=ZAP
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/connexion?_token=ILhRotvhAAfloaBBijKO91agC0MY5S9W9zxVqEFq&connect_mode=email&email=foo-bar%40example.com&emailtel=ZAP&indicatif=ZAP&password=ZAP&tel=ZAP
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/demande_passeport
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/demande_passeport
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/demande_passeport_diaspora
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/demande_passeport_diaspora
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/demande_passeport_resident
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session

URL	https://monpasseport.ngser.com/demande_passeport_resident
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/faq
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/faq
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/inscription
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/inscription
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/modification_rdv
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/modification_rdv
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/modifier_rdv
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/modifier_rdv
Method	GET

Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/modifier_rdv_diaspora
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/modifier_rdv_diaspora
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/piece_a_fournir
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/piece_a_fournir
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/piece_a_fournir_diaspora
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/piece_a_fournir_diaspora
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/reclamation
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/reclamation
Method	GET
Parameter	XSRF-TOKEN
Attack	

Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/sampling
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/sampling
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/sitemap.xml
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/sitemap.xml
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/tuto_videos
Method	GET
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/tuto_videos
Method	GET
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	laravel_session
Attack	
Evidence	Set-Cookie: laravel_session
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	XSRF-TOKEN
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Instances	40

Solution	Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.
Reference	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html
CWE Id	614
WASC Id	13
Plugin Id	10011

Low	**Cross-Domain JavaScript Source File Inclusion**
Description	The page includes one or more script files from a third-party domain.
URL	https://monpasseport.ngser.com/inscription
Method	GET
Parameter	//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.2/jquery.min.js
Attack	
Evidence	<script type="text/javascript" src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.2/jquery.min.js"></script>
Instances	1
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	**X-Content-Type-Options Header Missing**
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://monpasseport.ngser.com/anim/anim.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/externalsources/jquery-modal/jquery.modal.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/externalsources/jquery.inputmask.bundle.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/externalsources/modernizr/modernizr.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	

Evidence	
URL	https://monpasseport.ngser.com/assets/externalsources/moment-recur.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/externalsources/moment.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/bootstrap-datepicker/js/bootstrap-datepicker.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/calendar.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/connexion.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/demandes.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/dynamics.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/form_validation.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/inscription.js

Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/main.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/master.js?id=4076315290aa10176745
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/plugins/cloudflare_jquery3.6.1.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/plugins/dynamics.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/js/sendEmail.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/aos/aos.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/bootstrap/js/bootstrap.bundle.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/counterup/counterup.min.js
Method	GET
Parameter	X-Content-Type-Options

Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/isotope-layout/isotope.pkgd.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/jquery.easing/jquery.easing.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/owl.carousel/owl.carousel.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/typed.js/typed.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/venobox/venobox.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/assets/vendor/waypoints/jquery.waypoints.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/flash/flash.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/googleapis/jquery-ui.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	

URL	https://monpasseport.ngser.com/jquery_lv/jquery.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/mdb5/js/mdb.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/modals/modals_customized.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/modernizr2.8.3/modernizr.min.js
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
URL	https://monpasseport.ngser.com/robots.txt
Method	GET
Parameter	X-Content-Type-Options
Attack	
Evidence	
Instances	34
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	http://msdn.microsoft.com/en-us/library/ie/gg622941%28v=vs.85%29.aspx https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	**Information Disclosure - Sensitive Information in URL**
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	https://monpasseport.ngser.com/connexion?_token=ILhRotvhAAfloaBBijKO91agC0MY5S9W9zxVqEFq&connect_mode=email&email=foo-bar%40example.com&emailtel=ZAP&indicatif=ZAP&password=ZAP&tel=ZAP
Method	GET
Parameter	_token
Attack	
Evidence	_token

URL	https://monpasseport.ngser.com/connexion?_token=ILhRotvhAAfloaBBijKO91agC0MY5S9W9zxVqEFq&connect_mode=email&email=foo-bar%40example.com&emailtel=ZAP&indicatif=ZAP&password=ZAP&tel=ZAP
Method	GET
Parameter	email
Attack	
Evidence	foo-bar@example.com
URL	https://monpasseport.ngser.com/connexion?_token=ILhRotvhAAfloaBBijKO91agC0MY5S9W9zxVqEFq&connect_mode=email&email=foo-bar%40example.com&emailtel=ZAP&indicatif=ZAP&password=ZAP&tel=ZAP
Method	GET
Parameter	password
Attack	
Evidence	password
Instances	3
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	200
WASC Id	13
Plugin Id	10024

Informational	**Re-examine Cache-control Directives**
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://monpasseport.ngser.com
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/accueil
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/connexion
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/connexion?_token=ILhRotvhAAfloaBBijKO91agC0MY5S9W9zxVqEFq&connect_mode=email&email=foo-bar%40example.com&emailtel=ZAP&indicatif=ZAP&password=ZAP&tel=ZAP
Method	GET

Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/demande_passeport
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/faq
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/inscription
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/modification_rdv
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/piece_a_fournir
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/piece_a_fournir_diaspora
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/reclamation
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/robots.txt
Method	GET
Parameter	Cache-Control
Attack	

Evidence	
URL	https://monpasseport.ngser.com/sampling
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/sitemap.xml
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/tuto_videos
Method	GET
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
URL	https://monpasseport.ngser.com/find_contact
Method	POST
Parameter	Cache-Control
Attack	
Evidence	no-cache, private
Instances	17
Solution	Whenever possible ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control
CWE Id	525
WASC Id	13
Plugin Id	10015